Business Continuity and Disaster Recovery Policy

POL-COMP-007 · Version 2.5 · Effective 2025-03-20

1. Purpose

The purpose of this Business Continuity and Disaster Recovery Policy (POL-COMP-007, version 2.5) is to establish a framework for ensuring the availability of critical systems and data at Acme Corp in the event of a disruption. This document outlines the procedures and responsibilities for maintaining operations during and after a disaster, thereby minimizing potential impacts on business operations and customer services.

2. Scope

This policy applies to all systems critical to Acme Corp's operations, including:

- Ledger DB
- Kafka Cluster
- Payment Gateway
- Auth Service

It encompasses all employees, contractors, and third-party service providers who have access to, or operate on, these systems.

3. Policy Statements

3.1 Business Continuity Objectives

Acme Corp aims to ensure that its critical services remain operational during a disruption. The specific goals include:

- Tier-1 systems having a Recovery Time Objective (RTO) of 1 hour and a Recovery Point Objective (RPO) of 15 minutes.
- The Ledger DB having a stricter RTO of 30 minutes and an RPO of 5 minutes.

3.2 Disaster Recovery Testing

Disaster recovery tests will be conducted twice a year to validate the effectiveness of this policy. These tests will simulate various disaster scenarios to assess the capability of the organization to recover its critical systems and data.

3.3 Backup and Retention Procedures

To safeguard against data loss, backups will be taken daily for all critical systems. The backup data will be retained for a period of 35 days. The frequency and retention period are designed

to ensure that data can be restored to a point before the disruption occurred.

3.4 Incident Response

In the event of a disaster, the Incident Response Policy (POL-COMP-003) will guide the response efforts. It is essential that all personnel involved are familiar with the protocol for reporting incidents and executing the recovery plan.

3.5 System-Specific Recovery Procedures

3.5.1 Ledger DB Recovery

• In the event of a primary failure (INC-2025-012: Ledger DB primary failure), the Ledger DB recovery procedures outlined in SOP-OPS-014: Database Failover must be followed to restore services within the defined RTO and RPO.

3.5.2 Kafka Cluster Recovery

• For incidents involving the Kafka Cluster, such as Kafka consumer lag delays fraud scoring (INC-2025-008), the necessary steps from the Kafka Operations Guide (MAN-ENG-003) should be implemented to ensure data continuity and minimize operational disruptions.

3.5.3 Payment Gateway Recovery

• The procedures for recovery of the Payment Gateway, including handling payment latency spikes (INC-2025-031), will be based on the guidelines provided in the Payment Gateway Runbook (MAN-ENG-001).

3.5.4 Auth Service Recovery

• In case of incidents affecting the Auth Service, such as auth token validation failures (INC-2025-003), recovery actions must adhere to the architecture protocols set forth in the Auth Service Architecture document (MAN-ENG-002).

3.6 Communication Plan

A communication plan will be established to inform all stakeholders of the status of recovery efforts. The on-call engineer and Incident Commander will be responsible for relaying information to relevant parties in a timely manner.

4. Roles and Responsibilities

The following roles carry specific responsibilities in the implementation of this policy:

• **The Owning Team**: Responsible for maintaining the integrity of their systems and ensuring that necessary backup and recovery procedures are documented and tested.

• **The On-Call Engineer**: Tasked with executing recovery actions as outlined in this policy and related documents during incidents.

- **The Incident Commander**: Oversees the incident response process, ensuring all personnel are informed and that recovery objectives are met.

5. Exceptions

Any exceptions to this policy must be documented and approved by the relevant governing body. Exceptions may be considered for specific circumstances, such as temporary adjustments to backup frequencies or recovery objectives based on business needs. However, such exceptions must not compromise security or operational integrity.

6. Enforcement

Compliance with this policy is mandatory. Violations of this policy may result in disciplinary action, up to and including termination of employment or contract. Regular audits will be conducted to ensure adherence to the policy and to identify areas for improvement.

7. Related Documents

The following documents are related to this policy and provide additional guidance on specific areas of business continuity and disaster recovery:

- POL-COMP-001: Data Retention Policy
- POL-COMP-002: Acceptable Use Policy
- POL-COMP-004: Access Control Policy
- SOP-OPS-014: Database Failover

This policy will be reviewed and updated as necessary to reflect changes in business operations, technology, and regulations. It is the responsibility of all personnel to familiarize themselves with this policy and to adhere to its guidelines.